
Cyberboswachters

De beste digitale stropers zijn ook de beste cyberboswachters

Dams Tim



IoT Security

We spraken in het eerste hoofdstuk al over de problemen die inherent zijn bij Internet-of-Things (IoT) apparaten en netwerken. Zo had je in 2016 het Mirai-botnet dat aantoonde hoe krachtig een botnet van IoT-apparaten kan zijn, puur door de grote hoeveelheid potentiële zombies.

Het is niet toevallig dat we dit boek afsluiten met het hoofdstuk omtrent IoT Security: alles (en meer) wat je in de voorgaande hoofdstukken hebt geleerd heb je namelijk nodig om IoT-netwerken te beveiligen. Er zijn zoveel potentiële manieren voor digitale stropers om misbruik te maken van een slecht beveiligd IoT apparaat of netwerk dat het complexe probleem van netwerken beveiligen nog ingewikkelder is geworden door de eigenschappen van IoT apparaten, namelijk:

- Van nature zijn ze **low-power**, daar ze vele dagen of weken moeten voortkunnen zonder te veel verbruik. Ingebouwde security protocols mogen dus geen grote percentages van het vermogen opsouperen, zeker niet als dat ten koste is van de hoofdbestaansredenen van het apparaat.
- Meestal, ook weer om een laag energieverbruik te behouden, hebben ze ook een **beperkte bandbreedte** ter beschikking (daarbij: beeld je de miserie op een wifi-netwerk in wanneer honderden kleine sensoren aan hoge bandbreedtes het netwerk mee gebruiken).
- Zowel de fysieke dimensies, en bovenstaande 2 eigenschappen, zorgen er ook voor dat IoT-apparaten meestal maar een beperkt aantal zaken *kan*. Het heeft niet altijd de netwerkverbindingsmogelijkheden die je nodig hebt (meestal heeft een apparaat of bluetooth, of wifi, of een bedrade aansluiting, maar zelden alle drie) en ook qua opslag en processormogelijkheden zijn de apparaten uiteraard vaak veel beperkter dan de kracht van computers en mobiele telefoons. Het grootste probleem echter hiervan is dat IoT-apparaten *by nature* vaak **niet evident zijn om te updaten**. Sommige apparaten kunnen bijvoorbeeld enkel geüpdate worden door fysiek aan het apparaat te zijn (en dan door de firmware te flashen bijvoorbeeld). Vanuit een fysieke beveiligingsconcept is dat goed, maar niet als je apparaten een kritieke beveiligingslek hebben die dringend gepatch'd moet worden.



We gaan nogal liberaal om met de term IoT-apparaat, waarbij we ook negeren dat er grote verschillen zijn tussen “Enterprise IoT” en “huis-tuin-en-keuken IoT”. Die eerste heeft meestal bijvoorbeeld wel zeer doordachte updatestrategieën en dergelijke, terwijl de slimme koelkast in je huis dat vermoedelijk niet zal hebben

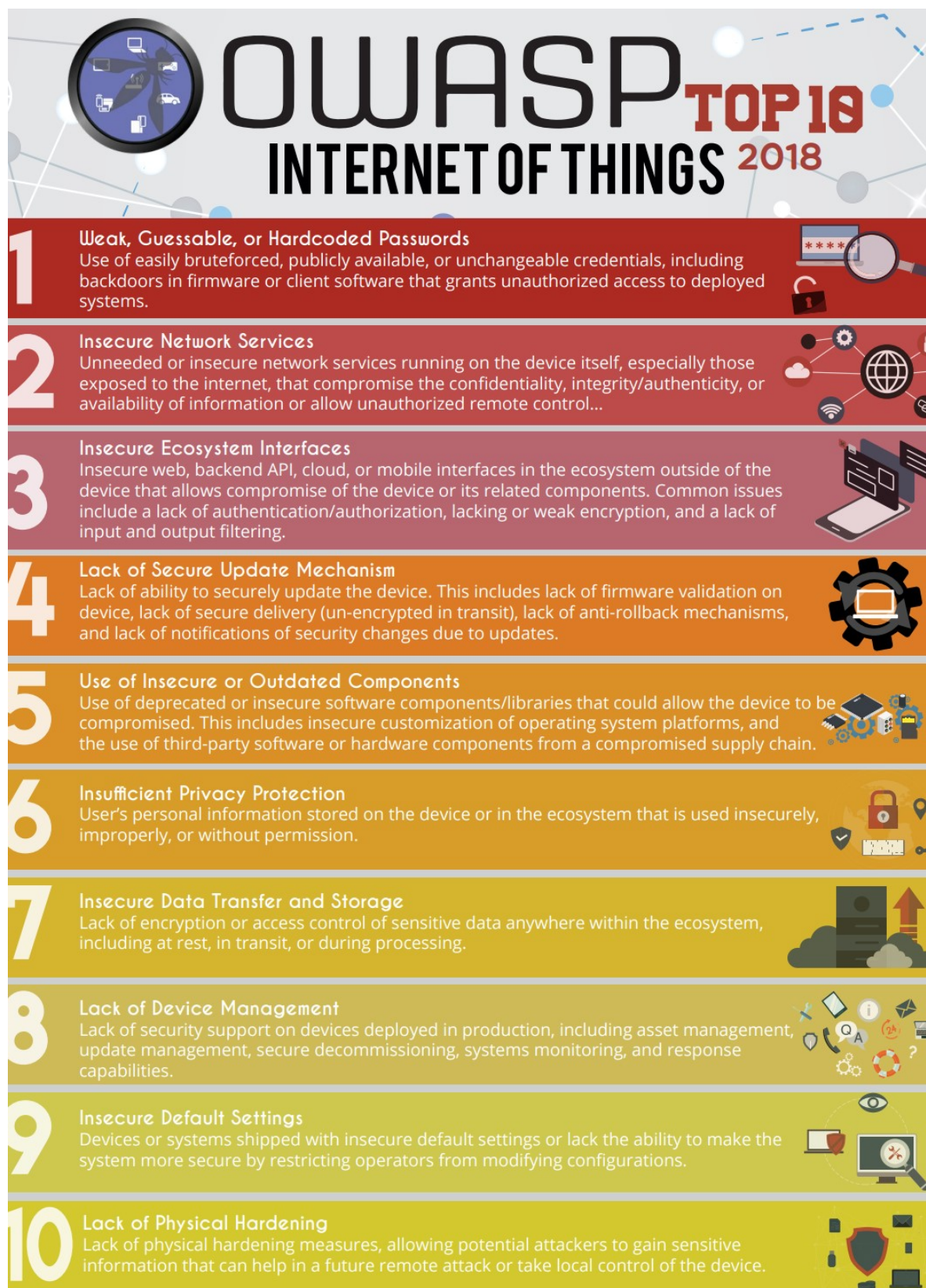
OWASP IoT Top 10

Het Open Web Application Security Project (OWASP) is een open source-project rond computerbeveiliging. Individuen, scholen en bedrijven delen via dit platform informatie en technieken. (bron Wikipedia). Ook de Belgische tak van OWASP is erg actief en een interessante organisatie indien je van plan bent om een carrière binnen de cybersecurity wereld op te bouwen. Ze organiseren geregeld (meestal gratis) workshops en evenementen.

Het OWASP heeft tal van erg interessante “Top 10” overzichten zoals de meest voorkomende webapp zwakheden, etc. Deze projecten bestaan meestal uit een hele reeks tools, *best practices* en gidsen en zijn dus de ideale manier om je te verdiepen binnen een specifiek cybersecurity domein. Eén van de actieve projecten is het “OWASP Internet of Things” project (beschikbaar via owasp.org/www-project-internet-of-things/) waarvan we de Top 10 hier zullen bespreken.



Bekijk zeker ook eens het IoT Goat project via github.com/OWASP/loTGoat/ dat is een *“insecure firmware based on OpenWrt and maintained by OWASP as a platform to educate software developers and security professionals with testing commonly found vulnerabilities in IoT devices. The vulnerability challenges are based on the OWASP IoT Top 10, as well as “easter eggs” from project contributors.”*



Figuur 0.1: Versie 2018, bron owasp.org)

Paswoorden

Ook bij IoT begint veiligheid uiteraard bij het hebben van goede, complexe, moeilijk te raden wachtwoorden. Bij IoT-apparaten komt echter een stevige drempel, zeker voor huis-tuin-en-keuken gebruikers: het aanpassen van sommige IoT-apparaten is soms erg omslachtig. Niet alle apparaten hebben een webpagina langs waar de gebruiker paswoorden kan aanpassen en moet dit via ofwel omslachtige, vreemde tools, oftewel (gruwel) door fysiek het apparaat te bedienen. Deze apparaten zijn natuurlijk niet gemaakt om complexe paswoorden eenvoudig in te voeren. Denk maar aan een digitale weegschaal: die heeft vaak een eenvoudig LED-scherm waarop je gewicht wordt getoond. Sommige weegschalen kan je vervolgens “bedienen” door links of rechts op de schaal te klikken, afhankelijk van wat je wilt doen. De auteur kan je garanderen: je paswoord zal niet lang zijn, als je een goed paswoord wilt invoeren zal je na enkele minuten in het zweet staan van de tapdans die je moet uitvoeren op je weegschaal.

Omdat het aanpassen van die paswoorden dus vaak zo omslachtig is, zullen gebruiker meestal opteren om het *default password* te gebruiken. Ze redeneren dat **dit simpele IoT apparaat zal niemand toch willen hacken**. “Wat kan een hacker nu doen met toegang tot mijn digitale thermometer.” Wat echter vergeten wordt is dat cyberstropers altijd op zoek gaan naar de weakest link, om die vervolgens te misbruiken om tot het eigenlijk doel te geraken. Kortom, ieder IoT-apparaat in je omgeving is een potentiële toegangspoort tot de rest van je netwerk!

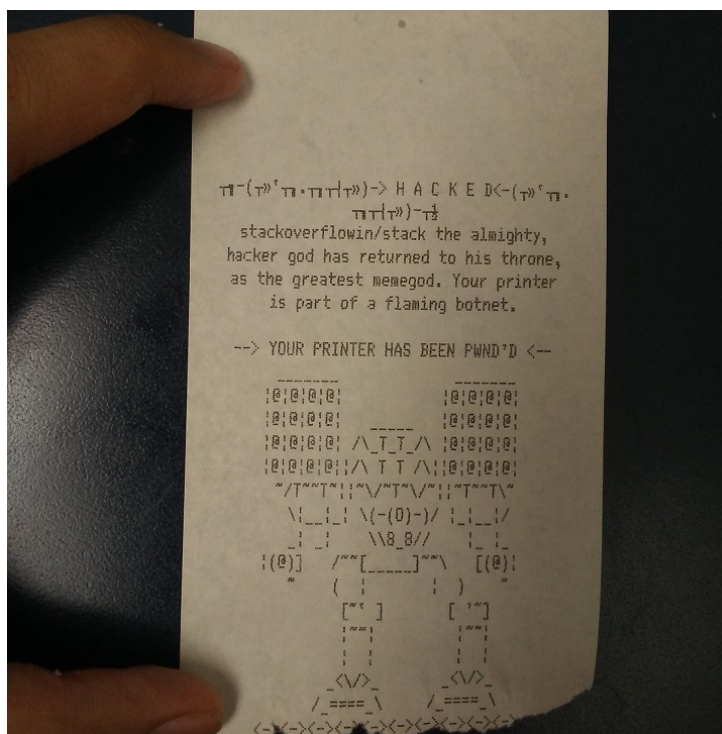
Ongebruikte of onveilige netwerkservices

Als je anno 2021 een printer koopt dan zal dit apparaat bijna altijd een IoT-apparaat zijn dat je toelaat om vanop afstand te printen. Echter, dergelijke apparaten hebben vaak tal van netwerkservices draaien waarvan de gewone huis-tuin-en-keuken gebruiker weinig of niets van afweet. Vergelijk dit bijvoorbeeld met Microsoft Windows: heb je al eens gekeken welke services allemaal permanent op je systeem draaien (Start -> uitvoeren -> `services.msc`) ? Dit soort diensten uitzetten behelst ook weer dat de gebruiker weet heeft van een webpagina met administrator-instellingen. Soms zijn die diensten op de koop toe essentieel voor de goede werking van het apparaat en ze uitzetten is dan geen optie. Maar wat als die service op zich inherent onveilig is ?! Zo zijn er apparaten die enkel *telnet*-sessies gebruiken om het apparaat in te stellen. Een telnet-sessie geeft je een remote shell die echter **ongeëncrypteerd** met het apparaat communiceert (in tegenstelling tot bijvoorbeeld SSH, Secure Shell, dat wél veilige communicatie aanbiedt).

Kortom, het is aangeraden om altijd te controleren welke services nu eigenlijk actief zijn op je apparaat.



In 2017 was er een grayhat hacker die vermoedelijk 150.000 printers vanop afstand in Nederland kon benaderen. Vervolgens printte hij “ludieke” berichten op de printers om de gebruikers er op te wijzen dat ze een onveilig apparaat gebruiken. In dit geval gebruikte hij poort 9100 van de printer die in veel merken wordt gebruikt om vanop afstand print-opdrachten door te sturen.



Figuur 0.2: Bron afbeelding en artikel:

<https://www.inktweb.nl/blog/hacker-neemt-150-000-printers-over/>

Bronnen

- 802.11 Wireless Network (first edition), Gast, O'Reilly, ISBN: 0-596-0018-3
- Meerdere boeken van William Stallings (Computer Security, Cybersecurity, etc.)

